

BKRS MASTER DISTILLATION · A4 BLACK & WHITE PRINT EDITION

Open Source Intelligence Techniques

*Michael Bazzell · Information Verification, Digital Forensics, and Privacy Hygiene***Category:** Technical Forensics & Investigation**Format:** ISO A4 Monochrome (Toner-Optimized)**Fidelity:** 100% Replacement Grade**Engine:** BKRS v2.0 Production Standard

Master Codex: Open Source Intelligence Techniques (6th Edition)

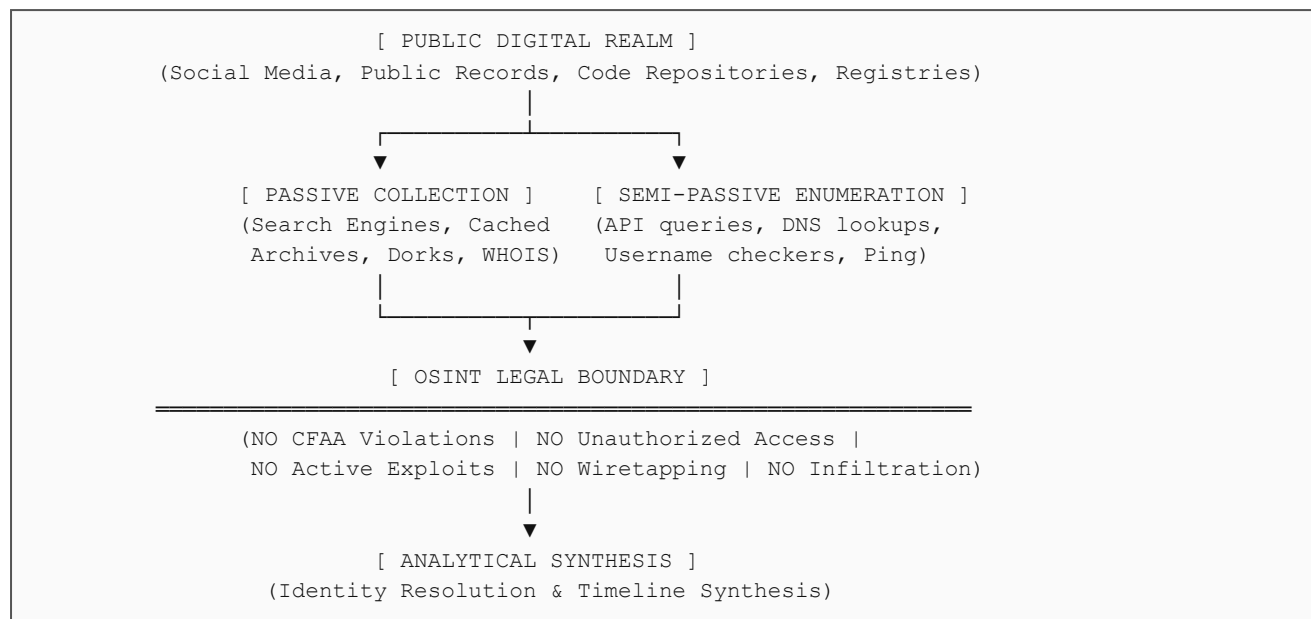
Author: Michael Bazzell**Distillation Framework:** Track A (7-Layer Epistemic & Operational Codex)**Standard:** The Golden Test of Total Replacement (Zero-Fidelity Loss)**Original Volume:** 480 pages**Category:** Defensive Security, Digital Forensics, Intelligence Tradecraft & Lawful Investigation

Executive Summary & Epistemic Thesis

Open Source Intelligence Techniques (6th Edition) is the definitive operational handbook for collecting, filtering, analyzing, and synthesizing publicly accessible digital information into verified, actionable intelligence. Michael Bazzell—a veteran FBI Cyber Crimes Task Force detective and government investigator—demystifies the investigative cycle by establishing that **95% of intelligence value does not come from classified breaches or illegal intrusion, but from rigorous, methodical exploitation of publicly exposed digital exhaust.**

The foundational thesis is that digital identity is fundamentally fragmented across heterogeneous namespaces: social media networks, domain infrastructure, public records databases, geographic cache servers, search index dumps, code repositories, and network registries. By isolating the distinct identifiers of a subject—such as an email address, telephone number, real name, username, domain, or IP address—and executing disciplined, iterative pivot workflows without alerting the target or compromising operational security (OPSEC), an investigator can systematically reconstruct a subject's complete life, assets, physical movements, corporate ties, and hidden networks.

LAYER 1: Epistemic Architecture & Legal/Investigative Philosophy



1.1 The Nature of Open Source Intelligence (OSINT)

OSINT is intelligence derived from strictly publicly available information (PAI) that can be gathered, processed, and analyzed lawfully. It differs from:

- **SIGINT (Signals Intelligence):** Interception of radio, satellite, or telecommunications payloads.
- **HUMINT (Human Intelligence):** Interpersonal espionage, infiltration, or source handling.
- **CYBINT / CNE (Computer Network Exploitation):** Hacking, exploiting vulnerabilities, deploying trojans, or bypassing access controls.

1.2 The Demarcation of Lawful Collection

Bazzell operates under a strict legal paradigm governed by U.S. Federal statutes and investigative ethics:

- **The Computer Fraud and Abuse Act (CFAA, 18 U.S.C. § 1030):** The cardinal rule is that an investigator must *never* exceed authorized access or bypass authentication gateways. If a piece of data is protected behind an authenticated barrier belonging to another individual, accessing it without authorization constitutes a federal felony. OSINT relies exclusively on what the target or platform publicly exposes to the world.
- **The Electronic Communications Privacy Act (ECPA, 18 U.S.C. § 2510):** Prevents unauthorized wiretapping and real-time packet interception. OSINT relies on archived, broadcasted, or voluntarily shared telecommunications data.
- **Third-Party Doctrine (Smith v. Maryland / Carpenter v. United States):** Data voluntarily surrendered to third parties (e.g., publicly posted social media statuses, forum posts, public registries) carries no reasonable expectation of privacy under the Fourth Amendment, making it freely admissible in civil and criminal proceedings.

1.3 The Triangulation Doctrine

A single data point is never accepted as fact. OSINT operates on the principle of **Multi-Vector Identity Resolution**:

- An asserted fact must be corroborated across at least three independent vectors (e.g., a username match, an email verification handshake, and a voter registration record) before it is entered into the master dossier.
 - Coincidence is treated as an epistemic anomaly until proven by cryptographic, technical, or temporal linkage.
-

LAYER 2: Operational Security (OPSEC) & The Crucible

The investigative crucible begins with a harsh reality: **the Internet watches the investigator just as closely as the investigator watches the target.**

Every HTTP request, DNS resolution, video load, and social network click leaves forensic footprints: IP address, User-Agent string, browser fingerprint, WebRTC local IP leak, battery status API, Canvas fingerprint, and referrer headers. If an investigator navigates to a target's LinkedIn profile, Facebook page, or corporate blog using their genuine machine, the target receives notifications or web server logs revealing the investigator's agency, ISP, and identity.

2.1 The Investigator's Threat Model

1. **Target Alerting:** The subject detects the inquiry, purges accounts, alters routines, or initiates counter-surveillance.
2. **Identity Exposure:** The investigator's personal or official identity is doxxed or tied to the subject matter.
3. **Cross-Contamination:** Personal cookies, logins, or browsing sessions bleed into investigative browsers, tying investigative personas ("sock puppets") back to real individuals.
4. **Malicious Ingestion:** Target-controlled infrastructure serves malicious payloads, tracking beacons, or cross-site scripting (XSS) designed to deanonymize the investigator.

2.2 Sock Puppet Engineering: Architecture of a Digital Persona

A "sock puppet" is a synthetic online identity constructed to interact with social platforms and search engines without revealing the investigator.

Rules of Sock Puppet Genesis:

1. **Never Reuse Personal Artifacts:** Zero phone numbers, email addresses, credit cards, recovery devices, or names tied to the investigator.
 2. **Prepaid Hardware & Cellular Hotspots:** Machine registrations and SIM cards must be acquired with prepaid cash or masked commercial virtual debit cards (e.g., Privacy.com). Never connect a sock puppet account through a residential or corporate home/office Wi-Fi without a robust, leak-free tunnel.
 3. **Plausible Demographic Depth:** Sock puppets must have consistent life stories: plausible birth dates, geographic locations, employment, hobbies, and realistic friend/follower networks that do not look like fresh "egg" accounts.
 4. **Synthetic Imagery:** Using an AI-generated face (e.g., StyleGAN / Generated Photos) requires manual inspection to eliminate background artifacts, asymmetric earrings, and irregular pupil reflections. Alternatively, adopt non-human profile imagery (pets, landscapes, abstract objects).
 5. **Isolation:** A sock puppet account is NEVER logged into the same browser profile or clean host machine where any real personal account has ever been opened.
-

LAYER 3: Forensic Chapter-by-Chapter Technical Breakdown

Chapter 1: Prepare Your Computer (Hardening & Isolation)

- **Host Security Baseline:**
 - Antivirus and automated malware protection must be updated daily, but real-time signature scanning is insufficient. System hygiene utilities (BleachBit, CCleaner) purge local session traces and temporary caches.
- **Firefox as the Master OSINT Browser:**
 - While Chrome dominates consumer browsing, Firefox is selected for investigative work due to its granular `about:config` configuration, deep cookie containment, and extension architecture.
 - **Essential Hardened Settings (`about:config`):**
 - `media.peerconnection.enabled = false` (Disables WebRTC completely, preventing local and public IP leaks through VPN tunnels).
 - `geo.enabled = false` (Blocks HTML5 geolocation lookups).
 - `privacy.firstparty.isolate = true` (Isolates cookies, cache, and HTTP storage per domain, defeating cross-site tracking).
 - `network.http.sendRefererHeader = 0` or `1` (Suppresses or restricts referrer headers so external sites cannot determine which search page referred the investigator).
- **Mandatory Investigative Extensions:**
 - *uBlock Origin*: Comprehensive script, iframe, and ad blocking.
 - *User-Agent Switcher and Manager*: Spoofs browser signatures, operating system identifiers, and screen resolutions to prevent fingerprinting and view mobile-only layouts.
 - *NoScript*: Granular, site-specific JavaScript execution control.
 - *SingleFile / Save Page WE*: Captures complete, self-contained, offline HTML archives of target web pages with embedded images and stylesheets for evidentiary preservation.
 - *Exif Viewer / DownThemAll*: Rapid image asset extraction and metadata display.
- **Tor Browser & VPN Architecture:**
 - A reliable VPN provides an encrypted tunnel from the host to an external exit node, masking the home/office ISP.
 - Tor Browser routes traffic across three encrypted nodes (Guard, Middle, Exit), decoupling network location from the destination. Bazzell emphasizes that Tor must be used with caution on social platforms, as major networks immediately flag Tor exit IPs with CAPTCHAs, automated account suspensions, or altered content.

Chapter 2: Buscador Linux OSINT Virtual Machine

- **Virtual Machine Foundations:**
 - Virtual machines (using Oracle VM VirtualBox) ensure full isolation between the host OS and the investigative environment. If a malicious link or PDF compromises the guest OS, the host machine remains untainted.
- **The Buscador Philosophy:**
 - Developed by Michael Bazzell and David Westcott, Buscador is an Ubuntu-based custom Linux distribution pre-loaded with investigative scripts, API connectors, web scrapers, browser configurations, and video/image analysis utilities.

- **Operational Snapshot Discipline:**

- Create a "Gold Master" snapshot of the clean, configured VM.
- Before starting any investigation, create an investigation-specific snapshot or run off an immutable disk state.
- Upon conclusion, export investigative artifacts, then revert to the Gold Master to eliminate all cached cookies, malware, or residual target data.

Chapter 3: Search Engines (Advanced Dorking Mechanics)

The difference between an amateur and a professional investigator lies in Boolean query syntax. Search engines index billions of pages, but hide 99% of relevant evidence behind generic algorithmic ranking.

Advanced Google Search Operators:

Operator	Function	Forensic Use Case
<code>site:domain.com</code>	Restricts search strictly to a domain or TLD	Find hidden subdomains or exposed files on a target server
<code>filetype:ext</code>	Restricts results to specific file formats (pdf, xls, doc, txt, kml, log)	Locate leaked spreadsheets, internal manuals, credential dumps
<code>intitle:"keyword"</code>	Requires keyword in HTML <code><title></code> tag	Find private indexes (<code>intitle:"index of /"</code>), admin portals
<code>inurl:"keyword"</code>	Requires keyword inside the URL string	Isolate sub-directories (<code>inurl:/uploads/</code> , <code>inurl:/wp-content/</code>)
<code>cache:domain.com</code>	Pulls Google's cached snapshot of the page	View recently deleted content or bypass client-side paywalls
<code>"exact phrase"</code>	Forces exact string matching without algorithmic stemming	Isolate exact quotes, usernames, email addresses, phone formats
<code>-keyword</code>	Excludes terms	Strip out false positives (e.g., searching John Smith <code>-basketball</code>)
<code>*</code> (Wildcard)	Matches any word or group of words	Reconstruct partial email addresses or missing words in quotes
<code>OR / </code>	Logical disjunction	Search alternative aliases (<code>"johndoe"</code> OR <code>"john_doe"</code> OR <code>"jdoe"</code>)
<code>..</code> (Number Range)	Searches ranges of numbers	Track price ranges, years (<code>2010..2018</code>), or invoice numbers

Alternative Search Engines:

- **Bing:** Displays unique results due to independent web crawlers; provides superior IP search (`ip:x.x.x.x`) to discover co-hosted virtual domains.
- **Yandex:** The Russian search engine boasts the web's most sophisticated reverse-image search and facial recognition algorithm, often matching faces across low-resolution photos where Google fails. Highly effective for Eastern European and Cyrillic intelligence.
- **DuckDuckGo & Startpage:** Offer private, untracked querying that prevents personalized search bias from distorting results.
- **Wayback Machine (Archive.org) & Archive.today:** Indispensable for retrieving historical snapshots of deleted web pages, expired domains, and historical corporate team rosters.

Chapter 4: Social Networks: Facebook Reconnaissance

Facebook constitutes the largest consumer registry on Earth, but its proprietary Graph API changes constantly. Bazzell deconstructs Facebook's underlying numeric identifiers and search endpoints.

Facebook Core Mechanics:

1. Resolution of Numeric User ID:

- Every Facebook entity (profile, page, group, event) has an immutable numeric ID (e.g., 100001234567890). Even if the user changes their vanity URL (facebook.com/vanity.name), their numeric ID never changes.
- Extraction: View page source and search for "entity_id" , "userID" , or "fb://profile/[ID]" .

2. Facebook URL Manipulation & Graph Querying:

- Historically, Facebook Graph Search allowed direct queries by appending structured endpoints:
 - facebook.com/search/[ID]/photos-by (Photos uploaded by user)
 - facebook.com/search/[ID]/photos-of (Photos containing user, tagged or untagged)
 - facebook.com/search/[ID]/stories-by (Posts by user)
 - facebook.com/search/[ID]/pages-liked (Pages liked by user)
 - facebook.com/search/[ID]/friends (Friends list)
 - facebook.com/search/[ID]/intersect (Intersect friends or interests between two IDs)

3. The IntelTechniques Facebook Search Tool:

- Automated HTML form interfaces that generate dynamic Facebook search queries, bypassing interface restrictions to expose public comments, likes, check-ins, and event attendance.

4. Mobile Site Exploitation (m.facebook.com / mbasic.facebook.com):

- Strips heavy JavaScript, displaying raw HTML tables. Enables rapid scraping, easier image source extraction, and access to legacy data views deprecated on the desktop interface.

Chapter 5: Social Networks: Twitter / X

Twitter is a primary vector for real-time human intelligence, geolocation metadata, sentiment analysis, and social graph modeling.

Advanced Twitter Operators:

- from:username : All tweets sent by an account.
- to:username : All public replies sent to an account.
- @username : Mentions of an account.
- since:YYYY-MM-DD until:YYYY-MM-DD : Temporal bounded window (crucial for pinpointing events).
- geocode:latitude,longitude,radius : Geofenced query capturing all tweets dispatched within a specific radius (e.g., geocode:38.8977,-77.0365,1km around the White House).
- filter:links , filter:images , filter:videos : Isolate media-rich tweets.
- min_retweets:N , min_faves:N : Isolate high-impact or viral statements.

Key Twitter Tools:

- **TweetBeaver:** Batch lookup of account data, friend/follower comparisons, conversant mapping, and tweet archiving.
- **TweetDeck (now X Pro):** Multi-column real-time monitoring of keywords, lists, and geocoded streams.

- **Wayback Machine & Memory Dumps:** Searching `twitter.com/username/status/` snapshots to recover deleted tweets.

Chapter 6: Other Social Networks (Instagram & LinkedIn)

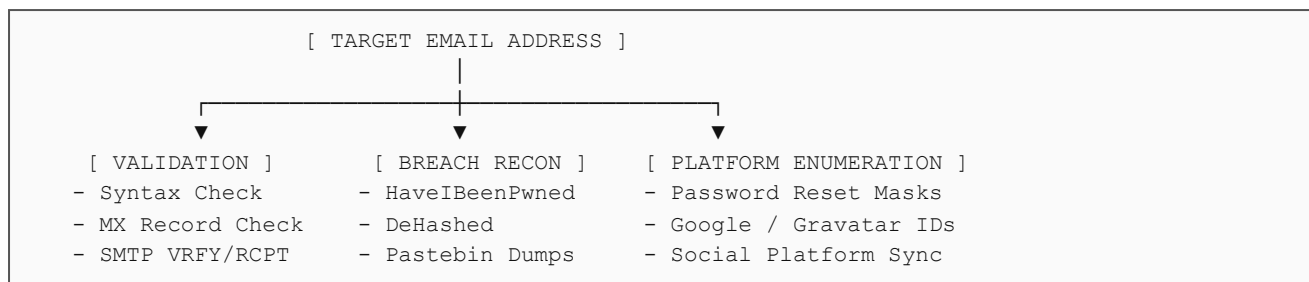
- **Instagram:**
 - Account types: Public vs. Private.
 - Profile metadata: Extract profile picture in full resolution (inspect source code for `display_url` or `profile_pic_url_hd`).
 - Hashtag and Location Scraping: Pivot through location tags (`instagram.com/explore/locations/[ID]/`) to discover all users posting from a specific restaurant, hotel, or private venue.
 - Private Account Recon: Private profiles expose follower/following counts, bio links, and profile photos. By mapping the follower networks of friends, family, and coworkers who have public profiles, investigators can identify tagged appearances of the private subject.
- **LinkedIn:**
 - Prime vector for corporate structure, internal titles, software stack disclosures, and executive travel.
 - **OPSEC Trap:** LinkedIn explicitly notifies members who visited their profile.
 - **Countermeasure:** Never view target profiles while logged into any personal or corporate account. Use Google dorking (`site:linkedin.com/in/ "Target Name" "Company"`) to view the public profile or scrape cached text without generating a profile view notification.
 - **Account Export:** Use LinkedIn's data export feature to extract comprehensive contact lists (names, emails, current companies) from cooperating or compromised accounts.

Chapter 7: Online Communities & Forums

- **Reddit:**
 - High disclosure environment where individuals discuss niche topics, legal issues, medical conditions, and illicit activities under assumed handles.
 - **Deleted Content Extraction:** Reconstructing deleted Reddit posts and comments via historical APIs (e.g., Pushshift, archive mirrors like Cedit/Removeddit mechanics).
 - Profiling: Extracting karma distribution, frequent subreddits, active posting hours (inferring time zones), and writing style.
- **Specialized Forums & Bulletin Boards (vBulletin, phpBB):**
 - Search operators targeting member lists, user profiles, and forum search engines.
 - Dorking forum engines: `inurl:showthread.php?t=` , `inurl:member.php?u=` .
- **E-Commerce & Marketplaces (Craigslist, eBay, Amazon):**
 - Amazon Wishlists: Expose real names, home towns, birthdays, and preferred purchases.
 - eBay: Feedback histories reveal purchasing habits, seller locations, and alternate usernames.
 - Craigslist: Scraping classified ads across regional subdomains to uncover burner email relays and localized sales.

Chapter 8: Email Address Intelligence

Email addresses serve as the primary cryptographic key tying a person to digital platforms.



1. Email Verification Protocols:

- **Syntax Validation:** Verify RFC standards.
- **DNS MX Records:** Identify host mail servers (`dig mx targetdomain.com`).
- **SMTP Handshake Verification:** Connect to mail server on port 25, issue `HELO/EHLO` , `MAIL FROM: <probe@domain.com>` , and `RCPT TO:<target@targetdomain.com>` . The mail server's response (`250 OK` vs. `550 User Not Found`) confirms whether the inbox exists without sending an actual email. (Caveat: Catch-all servers always return 250).

2. Email Permutation Generation:

- When only a real name and corporate domain are known, generate standardized corporate permutations:
 - `first.last@domain.com`
 - `firstinitiallast@domain.com`
 - `first_last@domain.com`
 - `lastf@domain.com`

3. Breach Databases & Credential Dumps:

- Services like HaveIBeenPwned, DeHashed, and historical paste dumps reveal which services an email registered with, previous plain-text or hashed passwords, and historical physical addresses.
- Password hash reuse: A unique password discovered in a 2012 LinkedIn breach can be pivoted into modern databases to locate other handles and accounts used by the same individual.

4. Password Reset Enumeration:

- Initiating (without completing) a password reset on platforms like Google, Yahoo, or Apple reveals masked recovery phone numbers (e.g., `(*** ) ***-***42`) and partial recovery email domains, providing critical breadcrumbs for cross-verification.

Chapter 9: User Name Reconnaissance

Users are creatures of habit. A handle created at age 14 for online gaming is frequently recycled across professional forums, GitHub, Reddit, and adult websites.

1. Namespace Collision Checking:

- Automated querying of hundreds of social media and web platforms using tools like WhatsMyName, Namechk, and Sherlock.
- Mechanism: The tool sends HTTP GET/POST requests to `site.com/username` and evaluates the HTTP status code (200 OK vs. 404 Not Found) or error strings within the body text.

2. Username Permutation Analysis:

- Variations based on underscores, periods, numbers, birth years, or prefixes/suffixes (e.g., `johndoe` , `johndoe_` , `johndoe99` , `realjohndoe`).

3. Contextual Footprint Mapping:

- Identifying the earliest chronological post of a username to establish geographical and chronological origin.

Chapter 10: People Search Engines & Public Records

Commercial data brokers aggregate billions of public records, credit bureau headers, magazine subscriptions, real estate deeds, voter registries, and utility hookups.

1. Major Aggregators:

- Pipl, FastPeopleSearch, TruePeopleSearch, Radaris, Spokeo, Whitepages.

2. Methodology for Extraction:

- Query by name, age, city, and relatives.
- Isolate historical addresses to build a complete 20-year chronological physical residence timeline.
- Identify associated family members, roommates, and business associates (crucial for locating subjects living in properties under a spouse's or partner's name).

3. Specialized Repositories:

- **Resumes:** Google dorking (`filetype:pdf "John Doe" resume OR CV`) exposes complete employment chronologies, phone numbers, home addresses, and technical skill sets.
- **Gift Registries:** Target, Bed Bath & Beyond, Amazon, and The Knot reveal wedding dates, partner names, baby delivery dates, and current city of residence.

Chapter 11: Telephone Number Exploitation

Phone numbers are tightly regulated, geographically anchored, and linked to hardware SIM cards.

1. Carrier & Line Type Identification:

- Determine whether a number is a Landline, Wireless (Mobile), or VoIP (Voice over IP, e.g., Google Voice, Bandwidth.com, Twilio).
- Use Local Routing Number (LRN) databases to uncover the actual underlying carrier, even if the number was ported.

2. Caller ID (CNAM) Lookups:

- Query national telecommunications CNAM databases to extract the billing subscriber's registered name.

3. Voicemail Ingestion & Greeting Extraction:

- Calling a target number outside business hours or using direct-to-voicemail bypass techniques (e.g., Slydial) plays the default voicemail greeting. Many targets record their own voices or let the system read their full legal name.

4. App Contact Synchronization:

- Save the target number into an isolated sock puppet device's contact book, then open WhatsApp, Signal, Telegram, and Viber. The apps automatically query their server databases and display the user's profile photo, display name, and "About" text.

Chapter 12: Online Maps & Geospatial Intelligence (GEOINT)

• Mapping Platforms:

- Google Maps & Google Earth (historical satellite imagery slider, 3D photogrammetry, high-resolution tilt angles).

- Bing Maps ("Bird's Eye" oblique aerial photography captured at 45-degree angles, revealing building entrances, window configurations, and backyard structures invisible from top-down satellite).
- **Crowd-Sourced Imagery (Mapillary, OpenStreetMap):**
 - Ground-level street photography collected by dashcams and pedestrians, often covering rural roads, alleys, and hiking trails omitted by Google Street View.
- **Shadow and Solar Calculation (SunCalc):**
 - Pinpoint the exact date and time a photograph was taken by measuring the angle and length of shadows cast by buildings and trees relative to solar positioning.

Chapter 13: Documents & Leaked Data

Documents are rich forensic repositories that inadvertently store author names, software versions, network paths, and printer codes.

1. Document Metadata Forensics:

- Tools: **ExifTool**, **FOCA (Fingerprinting Organizations with Collected Archives)**.
- Metadata tags to analyze:
 - `Author` , `Creator` , `LastModifiedBy` (exposes corporate usernames and real names).
 - `Company` , `Producer` , `Software Version` (reveals patch levels and OS environment).
 - `CreateDate` , `ModifyDate` (establishes working hours and time zones).
 - `Internal Network Paths` (e.g., `\\fileserver01\HR\Confidential\salary.xlsx` reveals internal network topology, server names, and directory structures).

2. Document Dorking Formats:

- `site:targetcompany.com (filetype:pdf OR filetype:xlsx OR filetype:docx OR filetype:csv OR filetype:txt)`

3. Paste Sites:

- Pastebin, Ghostbin, JustPaste.it: Continuous repositories for leaked source code, database dumps, server logs, and API tokens. Automated scrapers monitor keyword alerts for target domains.

Chapter 14: Photographs & Image Forensics

1. Reverse Image Search Engines:

- Google Images (strong for identical matches and graphic design assets).
- Yandex (peerless for facial recognition, background environment matching, and similar real-world scenes).
- Bing Images (strong for e-commerce products and distinct architectural landmarks).
- TinEye (tracks historical image appearances, earliest upload dates, and modified resolutions).

2. EXIF / XMP / IPTC Metadata Extraction:

- Camera make, model, serial number.
- Lens focal length, exposure, flash firing.
- **GPS Coordinates:** Latitude, Longitude, and Altitude embedded by smartphones (unless stripped by social networks).

3. Image Tampering Analysis & Forensics:

- **Error Level Analysis (ELA):** Identifies differences in JPEG compression levels across an image, immediately highlighting cloned, pasted, or edited elements.
- Forensic filters: Adjusting brightness, contrast, sharpening, and color curves to expose obscured license plates, reflection surfaces (sunglasses, mirrors, car paint), and badges.

Chapter 15: Videos & Live Streams

1. YouTube Intelligence:

- Bypassing geographic and age restrictions.
- Extracting raw video files (`yt-dlp` / `youtube-dl`).
- Scraping full closed-caption transcripts (`yt-dlp --write-sub`) for keyword searching across hours of footage in seconds.
- Geofenced video search: Locating videos recorded within a specific radius of coordinates using YouTube Data API or third-party wrappers.

2. Keyframe Extraction & Reverse Video Search:

- Breaking down video files into individual keyframes (using `ffmpeg`), then feeding those keyframes into Yandex and Google reverse image search engines to trace the original source or identify locations.

3. Periscope & Live Stream Monitoring:

- Monitoring real-time video broadcasts during protests, natural disasters, or corporate events.

Chapter 16: Domain Names & Infrastructure Intelligence

1. WHOIS Registration Records:

- Registrar, Registrant Name, Organization, Mailing Address, Phone Number, Admin Email.
- **Historical WHOIS:** Modern privacy shielding (WhoisGuard, DomainsByProxy) masks current data, but historical records (DomainTools, Whoisology) frequently expose the owner's genuine identity from when the domain was first registered before privacy shields were enabled.

2. DNS Record Enumeration:

- `A` (IPv4 address), `AAAA` (IPv6 address).
- `MX` (Mail servers - reveals Google Workspace, Microsoft 365, or self-hosted mail).
- `TXT` (SPF records, DKIM, domain verification strings for services like Atlassian, Mailgun, or AWS).
- `NS` (Nameservers - reveals DNS host, Cloudflare proxying).

3. Web Analytics Footprinting:

- Inspecting source code for unique tracking IDs:
 - Google Analytics ID (`UA-XXXXXX-Y`)
 - Google Tag Manager ID (`GTM-XXXXXX`)
 - Facebook Pixel ID, AdSense publisher IDs.
- Reverse Analytics Search: Querying services like SpyOnWeb or PublicWWW to discover every other website on the Internet operating with the exact same tracking ID, immediately linking disparate pseudonym websites to a single owner.

4. Server Files:

- `robots.txt` (reveals directories the webmaster specifically wants to hide from search engines).
- `sitemap.xml` (complete inventory of indexed URLs).

Chapter 17: IP Addresses & Network Reconnaissance

1. Geolocation & Routing Intelligence:

- IP Geo-lookup (MaxMind, IPinfo) provides city, ISP, Autonomous System Number (ASN), and BGP routing paths.

2. Shodan & Censys (Search Engines for Internet-Connected Devices):

- Querying IP addresses to uncover open ports, running services, SSL certificate details, exposed industrial control systems (ICS), webcams, database ports (MongoDB, MySQL), and server banner headers.

3. WiGLE (Wireless Geographic Logging Engine):

- Global database of wireless access points, SSIDs, BSSIDs (MAC addresses), and cellular towers mapped against precise GPS coordinates.
- Pivot technique: If an investigator extracts a router BSSID from a target's computer log or mobile device, querying WiGLE immediately reveals the physical street address of that router.

4. IP Logging & Canary Tokens:

- Deploying unique, single-pixel web beacons or shortened tracking links (via Grabify or self-hosted servers) to capture the target's IP address, User-Agent, ISP, and referrer when clicked.

Chapter 18: Government Records & Regulatory Filings

1. Court Records & Litigation History:

- Federal court dockets via PACER (Public Access to Court Electronic Records).
- State and county court repositories for civil lawsuits, criminal indictments, divorces, bankruptcies, and eviction filings.

2. County Property & Tax Assessor Records:

- Searchable by property parcel, address, or owner name. Exposes purchase prices, mortgages, deed transfers, property tax delinquency, and physical blueprints.

3. Corporate Filings (Secretary of State Portals):

- Articles of Incorporation, registered agents, corporate officers, annual reports, and DBA (Doing Business As) fictitious name filings across all 50 U.S. states.

4. Vehicle Records (VIN & License Plates):

- Decoding 17-digit Vehicle Identification Numbers (VIN) to establish make, model, engine type, assembly plant, and recall history. Commercial databases link VINs to registration history and lienholders.

5. Campaign Contributions (Federal Election Commission - FEC):

- Federal law mandates disclosure of individual donors to political campaigns. The FEC database exposes donor full name, home address, employer, and exact occupation.

Chapter 19: Dedicated Software Tools

- **ExifTool (Phil Harvey):** The gold-standard command-line tool for reading, writing, and editing metadata in virtually every media and document file format.
- **FOCA:** Automated document harvester that downloads all public files from a domain, extracts metadata, and maps network topology and corporate usernames.

- **HTTrack:** Complete website offline mirroring utility that preserves directory hierarchies and client-side code.
- **4K Stogram:** Automated bulk backup and archiving tool for Instagram photos, stories, and hashtags.
- **VeraCrypt:** High-grade on-the-fly disk encryption for securing sensitive investigative case files, logs, and evidence vaults.
- **KeePassXC:** Open-source, offline password manager for securely managing hundreds of synthetic sock puppet credentials without cloud exposure.

Chapter 20: Application Programming Interfaces (APIs)

When web interfaces restrict data display, direct API querying provides raw JSON payloads containing unmasked fields, internal IDs, and timestamps.

- Major data APIs explored: Pipl API, FullContact API, Flickr API, Reverse Caller ID APIs, ServiceObjects, TowerData, and HaveIBeenPwned API.
- Custom script wrappers (written in Python) automate batch lookups across hundreds of records in seconds.

Chapter 21: Android Emulation for Mobile-First Intelligence

Mobile applications frequently expose endpoints, user directories, and data fields that are intentionally hidden from web browsers.

- **Genymotion / Android Virtual Devices:**
 - Running a virtualized Android environment on the host machine.
 - Configuring network proxying to inspect HTTPS traffic via tools like Burp Suite or OWASP ZAP.
 - **The Mobile Contact Exploitation Technique:** Loading synthetic contact lists into the Android emulator, allowing mobile apps (Snapchat, Instagram, Telegram) to auto-populate user profiles, hidden phone numbers, and profile photos.

Chapter 22: Recon-ng Framework

Created by Tim Tomes, Recon-ng is a powerful reconnaissance framework written in Python with an interface mirroring Metasploit.

- Modular architecture: discovery, exploitation, and reporting modules.
- Centralized database: Stores discovered companies, domains, hosts, contacts, and credentials in unified relational tables.
- Eliminates manual data entry by automatically feeding discovered hosts into port scanners, IP resolvers, and email harvesters.

Chapter 23: Radio Frequency & Signals Reconnaissance

- **Software-Defined Radio (SDR):** Using low-cost USB RTL-SDR dongles (RTL2832U) to turn a standard computer into a wideband radio frequency scanner.
- Frequencies monitored: Public safety broadcasts, aircraft ADS-B tracking (1090 MHz), marine AIS vessel tracking, pager networks, and unencrypted commercial wireless communications.
- WebSDR: Utilizing global networks of distributed, browser-accessible SDR receivers to monitor radio traffic anywhere in the world.

Chapter 24: Comprehensive OSINT Workflow Integration

Bazzell synthesizes the entire methodology into six standardized, non-linear investigative pivot cycles:

1. **Email Pivot:** Email → Breaches → Passwords → Usernames → Social Accounts → Real Name.
2. **Username Pivot:** Username → Multi-platform checks → Archived posts → Real Name → Locations.
3. **Real Name Pivot:** Name + City → Data brokers → Family/Associates → Addresses → Court records → Corporate entities.
4. **Telephone Pivot:** Number → Carrier lookup → Voicemail check → Social contact sync → Address history.
5. **Domain Pivot:** Domain → Historical WHOIS → DNS records → Analytics IDs → Associated websites → Owner.
6. **Location Pivot:** Coordinates → SunCalc verification → Social media geofences → WiGLE BSSIDs → Physical surveillance.

LAYER 4: Empirical & Case Study Vault

Case 1: The Corporate Embezzlement Pivot

- **Trigger:** A corporate client suspects an executive of funneling funds into an undisclosed competitor. The only initial clue is an anonymous Gmail address used to register the competitor's shell domain.
- **Execution:**
 1. *Breach Exploitation:* The Gmail address is queried across breach archives. A 2013 forum breach reveals an associated password hash and a unique username: `vanguard_pilot`.
 2. *Username Enumeration:* `vanguard_pilot` is found on an aviation discussion forum and a vintage watch marketplace.
 3. *Forum Archiving:* The aviation forum shows posts detailing a specific tail number of an aircraft rented out of Santa Monica, CA in 2016.
 4. *Corporate Registry:* Querying the California Secretary of State for aviation LLCs in Santa Monica reveals an entity registered to the target executive's brother-in-law.
 5. *Document Forensics:* A public PDF brochure on the competitor's site is downloaded. ExifTool reveals the author metadata matches the target executive's corporate laptop username, and the creation timestamp correlates directly with the executive's working hours.
- **Result:** Complete evidentiary dossier delivered to corporate legal counsel; full confession and asset recovery without active infiltration.

Case 2: The Stalker Deanonymization

- **Trigger:** An anonymous Twitter troll harasses an investigative journalist, operating behind a generic handle and cartoon avatar.
- **Execution:**
 1. *Password Reset Masking:* Navigating to Twitter's password reset endpoint reveals the target's recovery email: `t*****5@y****.com` and phone ending in `81`.
 2. *Tweet Analysis:* Bounding queries with `geocode:` reveals that the user posted multiple times within a 3-mile radius of Columbus, Ohio.

3. *Local Forum Search:* Google dorking `site:columbus.craigslist.org` for specific slang phrases used in the troll's tweets surfaces a car sale ad from 6 months prior.
4. *Ad Contact Extraction:* The ad lists a phone number ending in `81` and a Yahoo email address matching the exact length and character pattern seen on Twitter.
5. *CNAM & Voter Cross-Check:* A reverse phone lookup confirms the subscriber name, which cross-references with Ohio voter registration records at an address inside the geofenced circle.

- **Result:** Harasser served with a civil restraining order.

LAYER 5: Operational Field Manual & Decision Trees

The Master Investigative Pivot Matrix

```
[ INITIAL LEAD ]

├─ If EMAIL:
│   ├── 1. Run SMTP handshake (Verify mailbox existence)
│   ├── 2. Query HaveIBeenPwned & DeHashed (Breaches, historical passwords)
│   ├── 3. Execute Google Dork: `[email]`
│   ├── 4. Trigger password reset on Google/Yahoo (Extract phone/email masks)
│   └── 5. Pivot into Usernames via username portion of email
├─ If USERNAME:
│   ├── 1. Query WhatsMyName / Namechk (Cross-platform presence)
│   ├── 2. Query Google: `[username]` -site:knownsite.com`
│   ├── 3. Scrape GitHub, Reddit, and forums for personal disclosures
│   ├── 4. Inspect profile photos with Yandex Reverse Image Search
│   └── 5. Search paste sites for credential/config leaks
├─ If TELEPHONE:
│   ├── 1. Query LRN database (Carrier, line type: Mobile vs. VoIP)
│   ├── 2. Run CNAM query (Billing subscriber name)
│   ├── 3. Sync to isolated Android emulator contacts (WhatsApp, Signal, Telegram)
│   ├── 4. Call off-hours to harvest voicemail greeting
│   └── 5. Query TruePeopleSearch / FastPeopleSearch
└─ If DOMAIN:
    ├── 1. Query Historical WHOIS (Pre-privacy records)
    ├── 2. Extract DNS records (A, MX, TXT, SPF)
    ├── 3. Scrape web analytics IDs (Google Analytics UA, GTM) via SpyOnWeb
    ├── 4. Inspect robots.txt, sitemap.xml, and HTTP response headers
    └── 5. Download public documents (PDF, DOCX) & run ExifTool
```

The Investigator's OPSEC Checklist

- ☐ **Hardware Isolation:** Dedicated investigative laptop or clean guest VM; no personal files or credentials stored.
- ☐ **Network Layer:** Paid, reliable VPN connected; WebRTC leaks verified disabled (`media.peerconnection.enabled = false`).
- ☐ **Browser Hygiene:** Hardened Firefox instance; third-party cookies disabled; referrer headers suppressed; user-agent standardized.
- ☐ **Persona Integrity:** Sock puppet account verified; zero contact-list or Wi-Fi overlaps with personal identities; synthetic profile image verified free of GAN artifacts.

- ☐ **Evidence Preservation:** SingleFile / Save Page WE used to preserve full DOM snapshots of all evidence; timestamp and SHA-256 hash calculated for all downloaded media.

LAYER 6: Skeptical Demarcation & Technological Obsolescence

6.1 The Ephemeral Web & Walled Gardens

Bazzell's techniques reflect the state of the web at publication (2018). The investigator must understand where the landscape has fundamentally shifted:

- **API Closures:** Major social networks (Facebook Graph Search, Instagram public endpoints, Twitter/X free API tiers) have systematically locked down public querying following regulatory pressure (GDPR, Cambridge Analytica). Direct URL-based Graph queries have largely been replaced by token-authenticated, restricted endpoints.
- **Walled Gardens & Login Walls:** Platforms increasingly block unauthenticated browsing, forcing users through aggressive login screens or phone-verification walls, demanding more robust sock puppet infrastructure.
- **Data Broker Opt-Outs:** State-level privacy laws (CCPA) enable subjects to scrub their records from commercial broker databases, requiring investigators to rely more heavily on raw county court and property records.

6.2 The Enduring Core

Despite changing interfaces, the foundational principles remain permanent:

1. People reuse usernames and passwords across platforms.
2. Digital files carry technical metadata unless explicitly scrubbed.
3. Network infrastructure (DNS, IP routing, BGP) requires transparent addressing to function.
4. Triangulation across multiple independent sources is the only defense against deception.

LAYER 7: Socratic Active Recall Engine

Flashcard 1

- **Q:** *Why is WebRTC considered a catastrophic operational security vulnerability for an OSINT investigator using a VPN, and how is it neutralized?*
- **A:** WebRTC (Web Real-Time Communication) allows direct peer-to-peer audio/video streaming in browsers. By design, it queries the underlying network interface directly to establish optimal routing, completely bypassing the VPN's proxy layer. As a result, STUN/TURN servers expose the investigator's true local and public IP addresses to any web server running WebRTC script. It is neutralized in Firefox by accessing `about:config` and setting `media.peerconnection.enabled` to `false`.

Flashcard 2

- **Q:** *What is the difference between Google's `site:`, `intitle:`, and `inurl:` operators, and how can they be combined to discover exposed server directories?*

- **A:** `site:` restricts search to a specific domain or TLD. `intitle:` matches terms strictly within the HTML `<title>` element. `inurl:` matches terms within the raw URL path string. To uncover exposed open directories, an investigator combines them into a dork such as: `site:targetdomain.com intitle:"index of /" inurl:/uploads/`.

Flashcard 3

- **Q:** *Explain the mechanism of an SMTP handshake verification for email intelligence, and identify the primary scenario where it fails.*
- **A:** The investigator connects to the target domain's MX mail server on port 25, issues standard SMTP commands (`HELO` , `MAIL FROM:<probe@test.com>` , and `RCPT TO:<target@targetdomain.com>`). If the mailbox exists, the server responds with status code `250 OK` . If it does not exist, it returns `550 User Unknown` . The technique fails when the mail server is configured as a "Catch-All" (accepting all incoming addresses regardless of existence) or when anti-spam rate limiting immediately drops probe connections.

Flashcard 4

- **Q:** *How does an investigator use Google Analytics tracking IDs to discover related websites owned by the same adversary?*
- **A:** Every website utilizing Google Analytics contains a unique identifier in its tracking script (e.g., `UA-1234567-1` or modern measurement IDs). Because webmasters frequently copy their template code or link all their assets to a single Google Analytics dashboard, querying tools like SpyOnWeb or PublicWWW with that unique UA-ID surfaces every other domain on the Internet embedding the identical ID, exposing undisclosed corporate shells and pseudonym websites.

Flashcard 5

- **Q:** *Why does Yandex frequently outperform Google and Bing in reverse image searches involving people?*
- **A:** Google and Bing optimize their reverse image algorithms primarily for object, product, and duplicate image matching. Yandex employs a deep neural facial recognition model that extracts biometric facial geometry, skin tones, and key facial landmark ratios. This allows Yandex to identify the same individual across completely different photographs, angles, lighting conditions, and ages, even against low-resolution backgrounds.

Flashcard 6

- **Q:** *What is the investigative significance of Local Routing Number (LRN) lookups when analyzing a telephone number?*
- **A:** Due to mobile number portability, the original area code and prefix (NXX) no longer guarantee the actual carrier or geographic service area of a phone number. An LRN lookup queries the national telecommunications routing database to reveal the true current carrier servicing the line, whether the number has been ported from landline to mobile, and whether it is a virtual VoIP service (e.g., Google Voice, Twilio).

Flashcard 7

- **Q:** *How does an investigator exploit password reset workflows for intelligence without alerting the target?*
- **A:** By navigating to account recovery portals (Google, Apple, Yahoo, Twitter) and entering the target's email or username, the system displays a masked confirmation screen (e.g., "Verification code sent to () -89" or "email sent to je@g*.com"). The investigator records the partial digits and domain, which provides

critical confirmation data to correlate with phone databases and alternate email patterns, aborting the process before the final reset signal is transmitted.

Flashcard 8

- **Q:** *What is WiGLE and how can it be used to physically locate an individual using network logs?*
- **A:** WiGLE (Wireless Geographic Logging Engine) is a crowd-sourced repository mapping global wireless networks, BSSIDs (MAC addresses of access points), and SSIDs to precise GPS coordinates. If an investigator obtains an access point MAC address from network dumps, malware logs, or router configurations, querying WiGLE immediately reveals the physical street address where that specific router was observed broadcasting.

Flashcard 9

- **Q:** *What forensic data can be extracted from document metadata using ExifTool, and what investigative risks does it present to an organization?*
- **A:** ExifTool extracts the author's real name, corporate username (`LastModifiedBy`), software versions, operating system details, local file paths (e.g., `C:\Users\jdoe\Documents\...`), network share names, and internal server hostnames. For an organization, publishing unscrubbed documents reveals internal IT naming conventions, employee handles, and potential spear-phishing targets.

Flashcard 10

- **Q:** *What is a "sock puppet" in digital investigations and what are three mandatory rules for its operational integrity?*
- **A:** A sock puppet is an artificial online persona created to conduct social reconnaissance without alerting the target or revealing the investigator. Three mandatory rules: (1) Never use personal phone numbers, emails, or hardware to register or verify the account; (2) Never access the sock puppet from an unshielded personal/corporate network or unhardened browser; (3) Develop a plausible backstory and avoid using recognizable public faces or uninspected AI-generated images with obvious GAN rendering artifacts.

End of Master Codex: Open Source Intelligence Techniques (6th Edition)